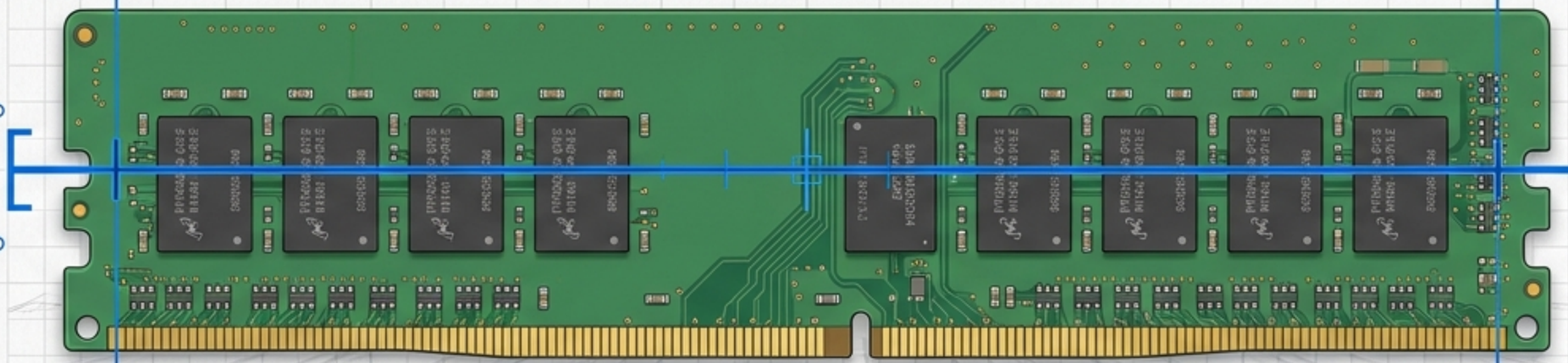
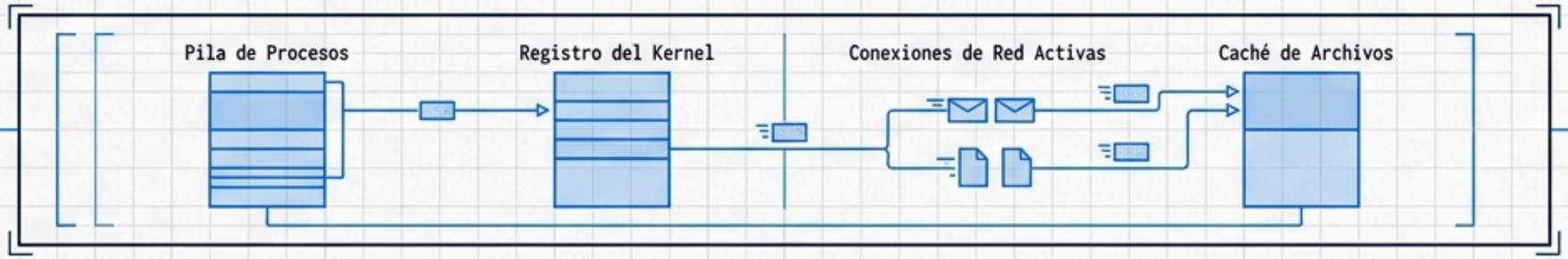
Análisis Forense de Memoria RAM: Persiguiendo lo Volátil

Guía metodológica para la adquisición, análisis y reconstrucción de ciberincidentes.

ESTADO: ACTIVO
PROTOCOLO: IDIP
VERSIÓN: 3.0

[INICIO ESCANEO] EXTRACCIÓN DE DATOS VOLÁTILES - ARTEFACTOS DE MEMORIA [FIN ESCANEO]

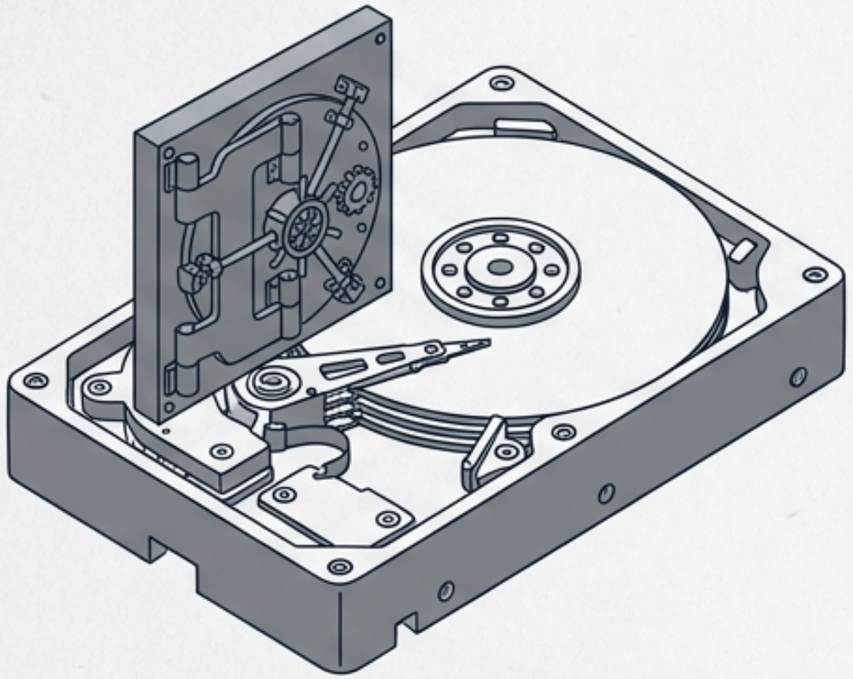




Gemini Notebook

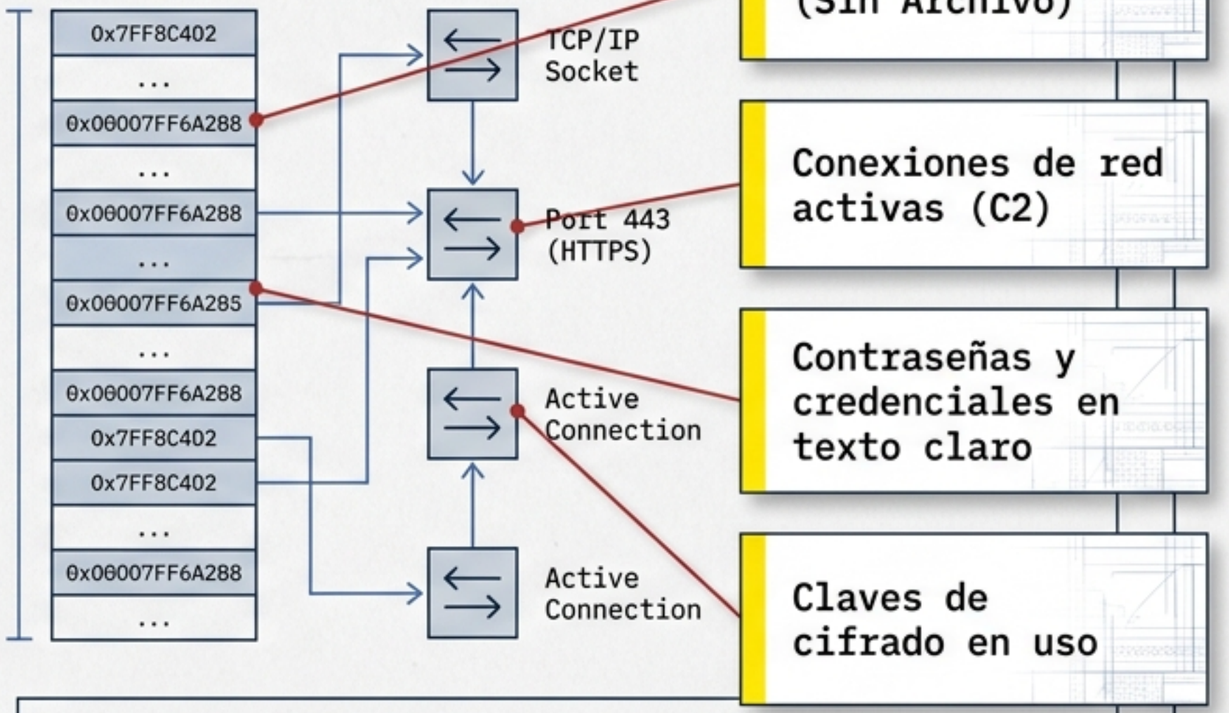
El punto ciego de la informática forense tradicional

Análisis de Disco



Conserva datos persistentes, pero es ciego ante ataques en ejecución. Los atacantes modernos ocultan sus huellas en el disco duro o lo cifran.

Análisis Volátil

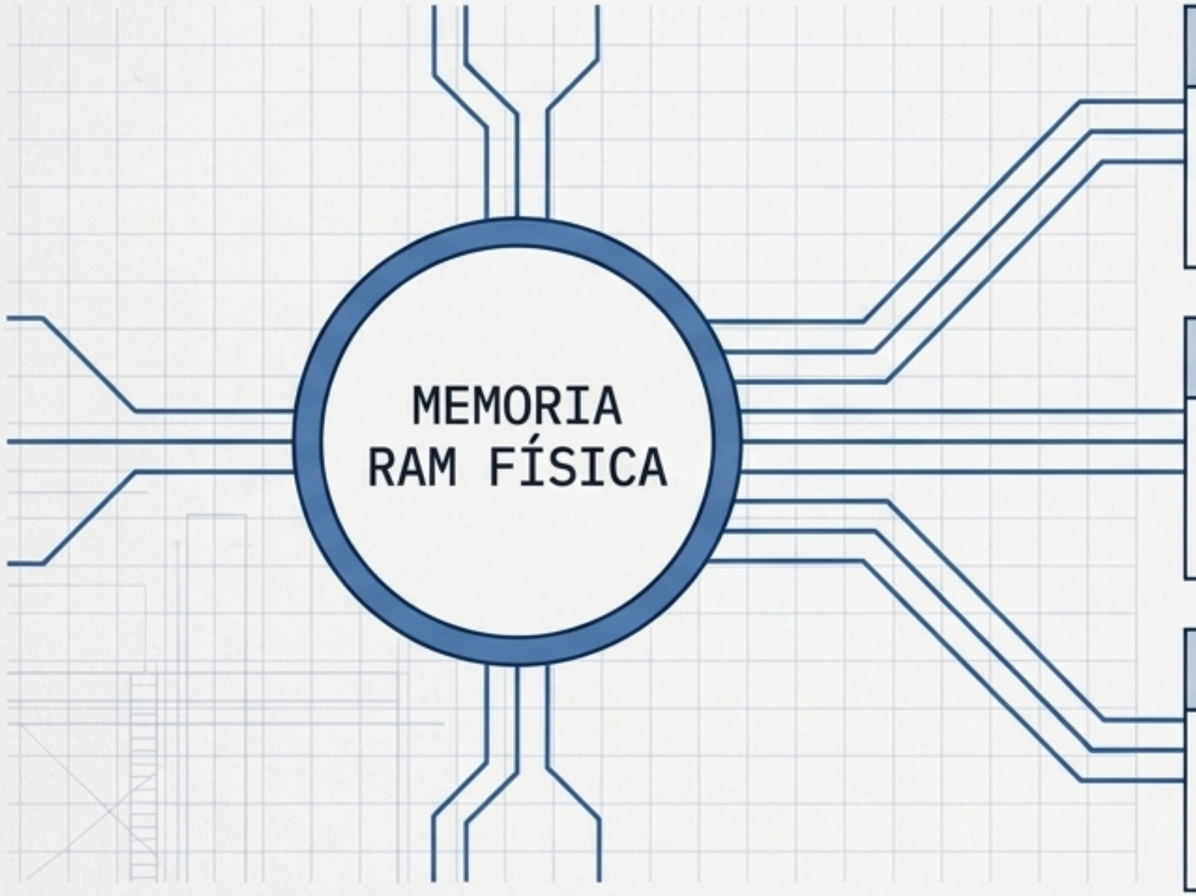


Captura el estado exacto del sistema en el instante del incidente.

Gemini Notebook

El ecosistema volátil del sistema operativo Windows

La evidencia volátil no reside exclusivamente en los chips físicos. El sistema operativo extiende su espacio de trabajo hacia el disco, creando artefactos vitales para el perito.



pagefile.sys

Archivo de paginación. Actúa como memoria virtual. Aloja fragmentos de procesos y datos expulsados de la RAM cuando esta se llena.

swapfile.sys

Archivo de intercambio. Introducido en Windows 8, maneja específicamente la memoria de las aplicaciones modernas/universales de Microsoft.

hiberfil.sys

Archivo de hibernación. Almacena el estado completo y exacto de la sesión para restaurarlo tras el apagado.

Gemini Notebook

La regla de oro del peritaje: Adquirir lo volátil primero

Preparación y Adquisición

Captura inmediata del volcado de memoria (.mem) antes de apagar el equipo.

Análisis

Aplicación de perfiles, reconocimiento de procesos y extracción de artefactos (ej. mediante Volatility).

Presentación

Reconstrucción de la línea temporal y generación del informe pericial.

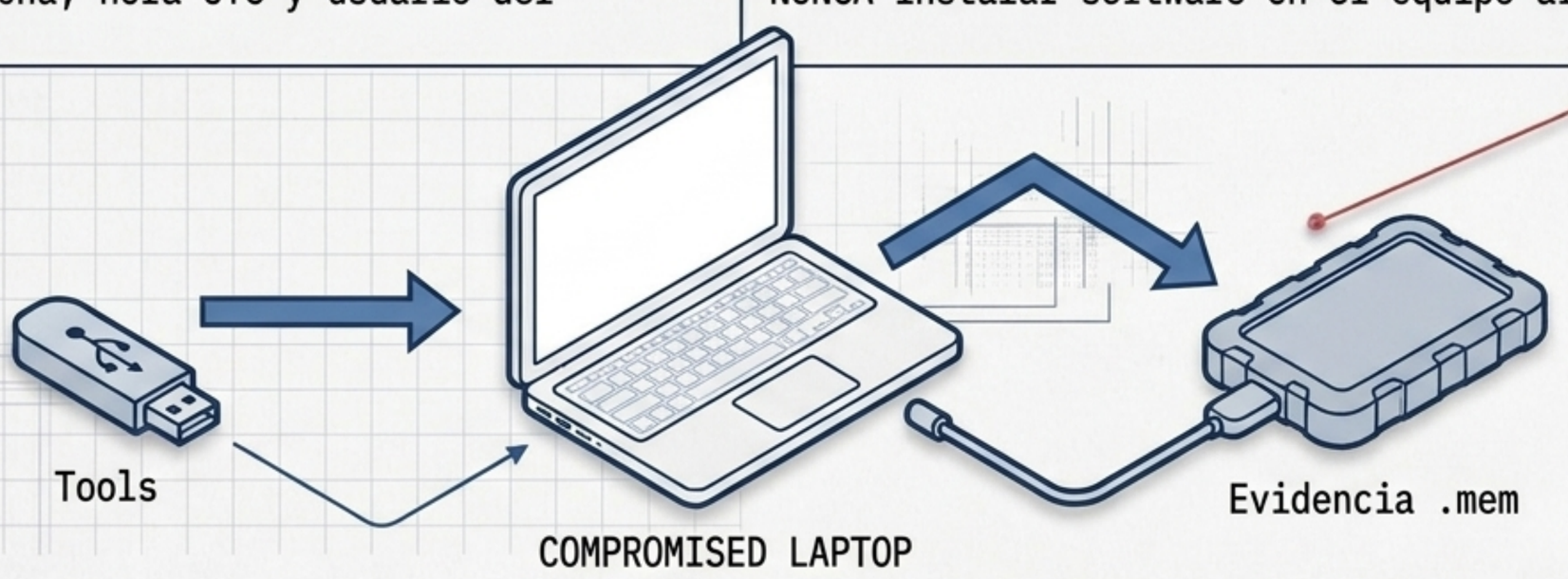


Cuidado con la contaminación: La mera acción de ejecutar software para volcar la memoria altera su contenido. Se deben utilizar herramientas forenses diseñadas para minimizar esta huella (zero-footprint).

Gemini Notebook

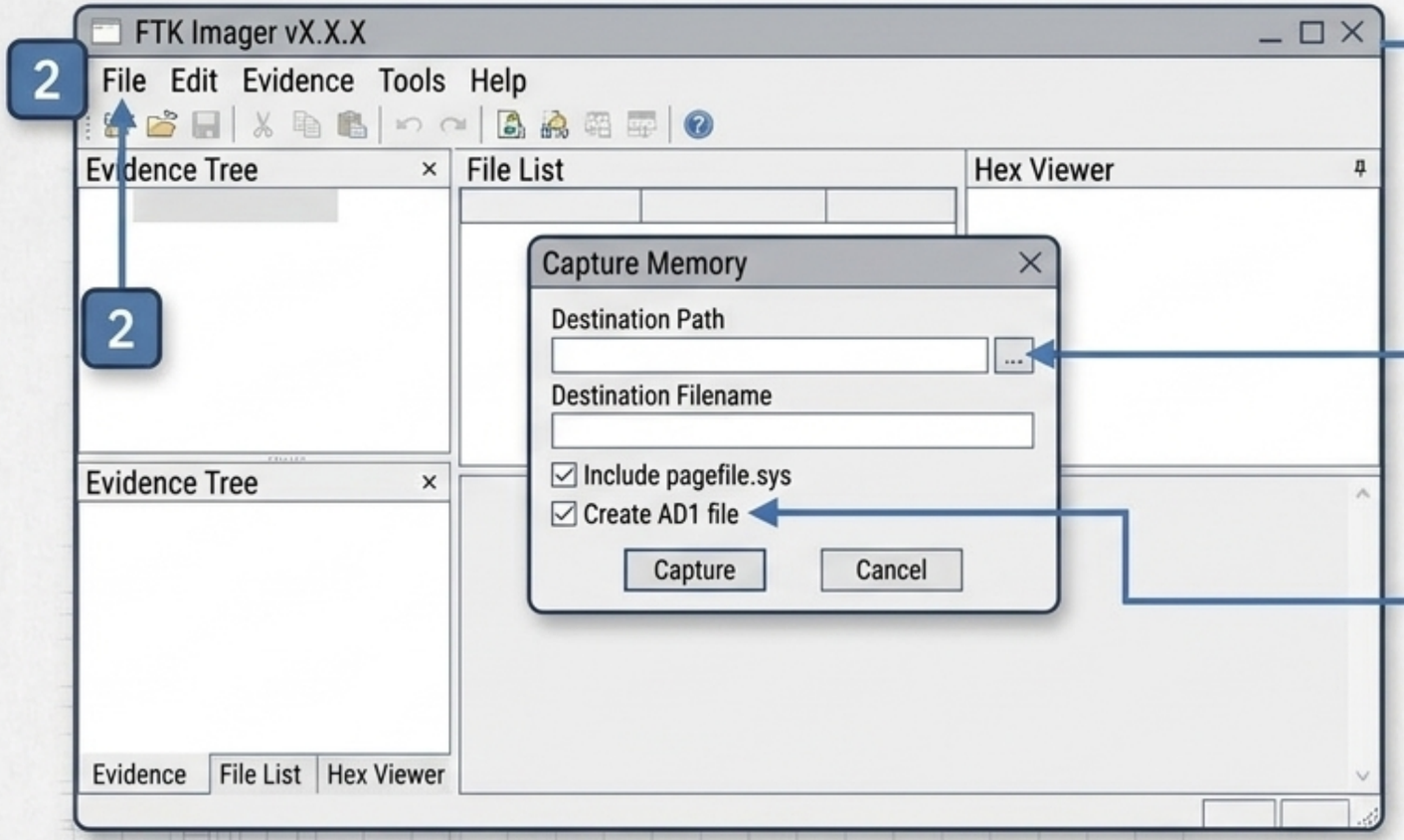
Protocolo de adquisición en caliente (Live Acquisition)

Reglas de Adquisición	
✅ Obligatorio	❌ Prohibido
Ejecutar herramientas desde un dispositivo USB extraíble. Almacenar el volcado (.mem o .raw) en un disco duro externo. Registrar la fecha, hora UTC y usuario del sistema.	NUNCA apagar o reiniciar el equipo antes de la captura. NUNCA guardar el archivo de volcado en el disco duro local de la máquina comprometida (sobrescribe evidencia eliminada). NUNCA instalar software en el equipo afectado.



Gemini Notebook

Ejecución táctica: Captura mediante FTK Imager



1. Ejecutar FTK Imager con privilegios de Administrador.
2. Seleccionar File > Capture Memory.
3. Definir el destino en el disco externo. Nomenclatura estándar: HOSTNAME_YYYYMMDD_HHMM.mem
4. Activar la opción para incluir pagefile.sys (crucial para recuperar datos paginados al disco) y generar formato AD1 si se requiere.

Alternativas: Utilidades de línea de comandos como WinPmem o comandos de hipervisor (ej. vboxmanage debugvm dumpvmcore para entornos virtualizados).

Gemini Notebook

La firma inmutable: Hashing y Cadena de Custodia

La validez legal de una adquisición volátil depende de demostrar que el archivo no ha sido alterado desde el momento de la captura.



Checklist de Custodia

- ✓ Calcular el hash SHA-256 o MD5 inmediatamente después del volcado.
- ✓ Registrar firmas en el formulario de Cadena de Custodia.
- ✓ Trabajar SIEMPRE sobre una copia del volcado, jamás sobre el archivo original.

Evidence Chain of Custody Tracking Form

CASE ID	Evidence Number
DFD-2024-601	E-001

Item Description	Quantity
Volcado de Memoria (memoria.dmp)	1 File, 16GB

Hash (SHA-256)	Date & Time (UTC)
c4b8e7a2d4...	2024-05-15 14:32:00 UTC

Acquired By	Location
Agent J. Doe	Secure Server R-12

Reason for Transfer
Initial Acquisition

Date	Time (UTC)	Released By (Name & Signature)	Received By (Name & Signature)	Reason for Transfer
2024-05-15	14:32	Agent J. Doe [Signature]	Evidence Locker [Signature]	Secure Storage

Gemini Notebook

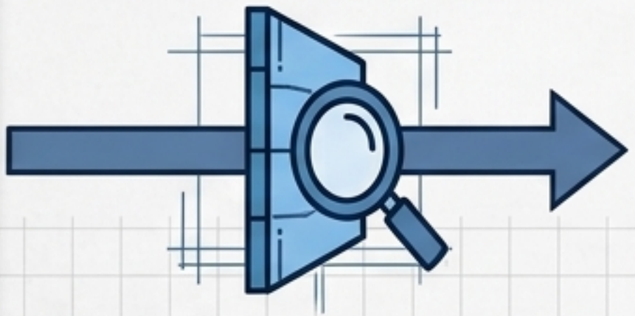
El Quirófano Digital: The Volatility Framework

Volatility es el estándar de la industria para analizar volcados de memoria, extrayendo estructuras internas del kernel del sistema operativo.

Raw Binary Data

```
01010011 10110001
00101110 01000001
01000001 ...
...
10101010 00111011
11000100 11100101
...
```

Perfil del Kernel
(Volatility Engine)



Procesos

PID	Nombre	Estado	Usuario
1221	python.exe	Pupsr	user
1003	vitue.sy	Enable	user
1003	...	Duper	user
1005	...	Pomota	user
1713	...	Power	users
1808	...	Pomota	user
2003	...	Powez	user
...	...	...	...
...	...	...	...

Sockets

Protocolo	Puerto	Dirección	Estado
TEP	5800	172.0.8.1	...
TCP	6800	172.0.8.0	...
T9P	5800	172.0.0.311	...

Credenciales

Sistema	Usuario	Hash/Clave	Dominio
Sistema	user		
System	user		

```
$ python vol.py -f memoria.dmp imageinfo
-> Identifica la estructura del kernel (ej. Win7SP1x64).
```

Evolución de la herramienta:

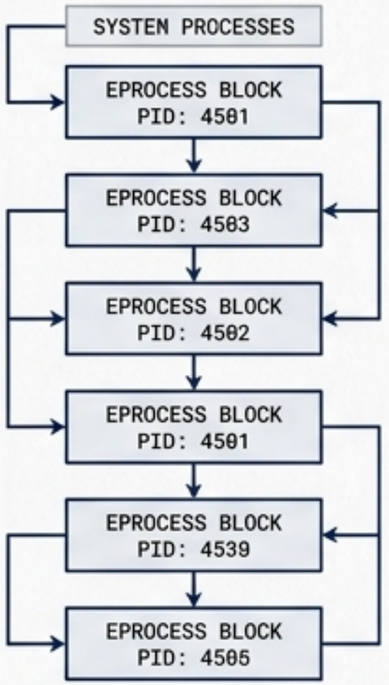
- ✓ Volatility 2.6: Requiere perfilado manual (--profile=Win7SP1x64).
- ✓ Volatility 3: Resolución de símbolos automatizada y mayor velocidad.

Gemini Notebook

Matriz de Reconocimiento: Desenmascarando Rootkits

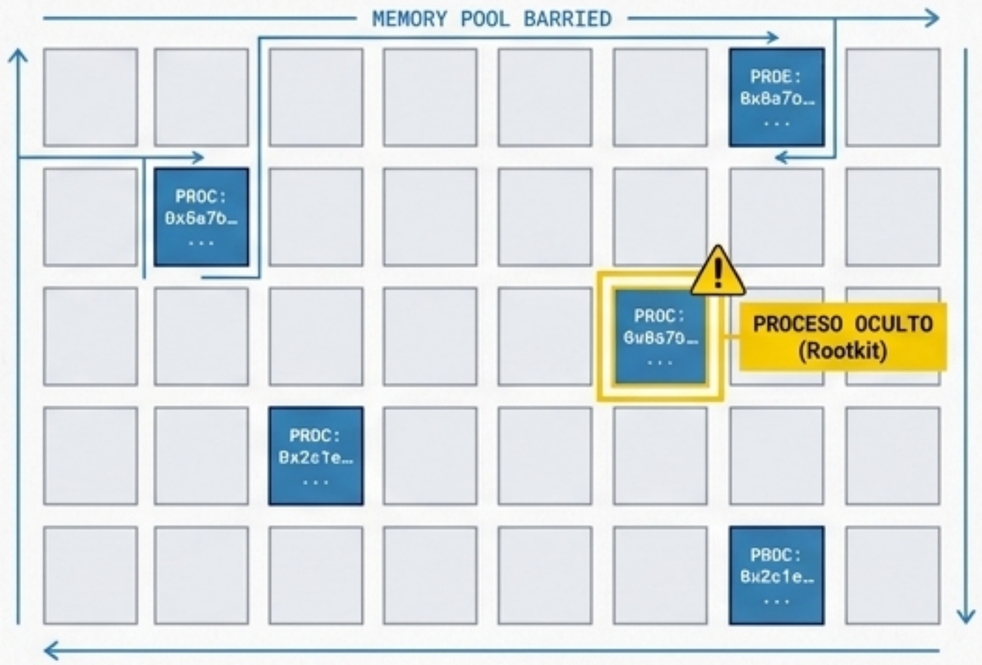
El atacante avanzado oculta sus procesos desenlazándolos de las listas oficiales del sistema. El perito cruza fuentes para hallar discrepancias.

pslist (El Gestor Oficial)



Recorre la **lista doblemente enlazada de bloques EPROCESS.**
Si el malware manipula esta lista, el proceso se vuelve invisible.

psscan (El Escáner de Piscinas)



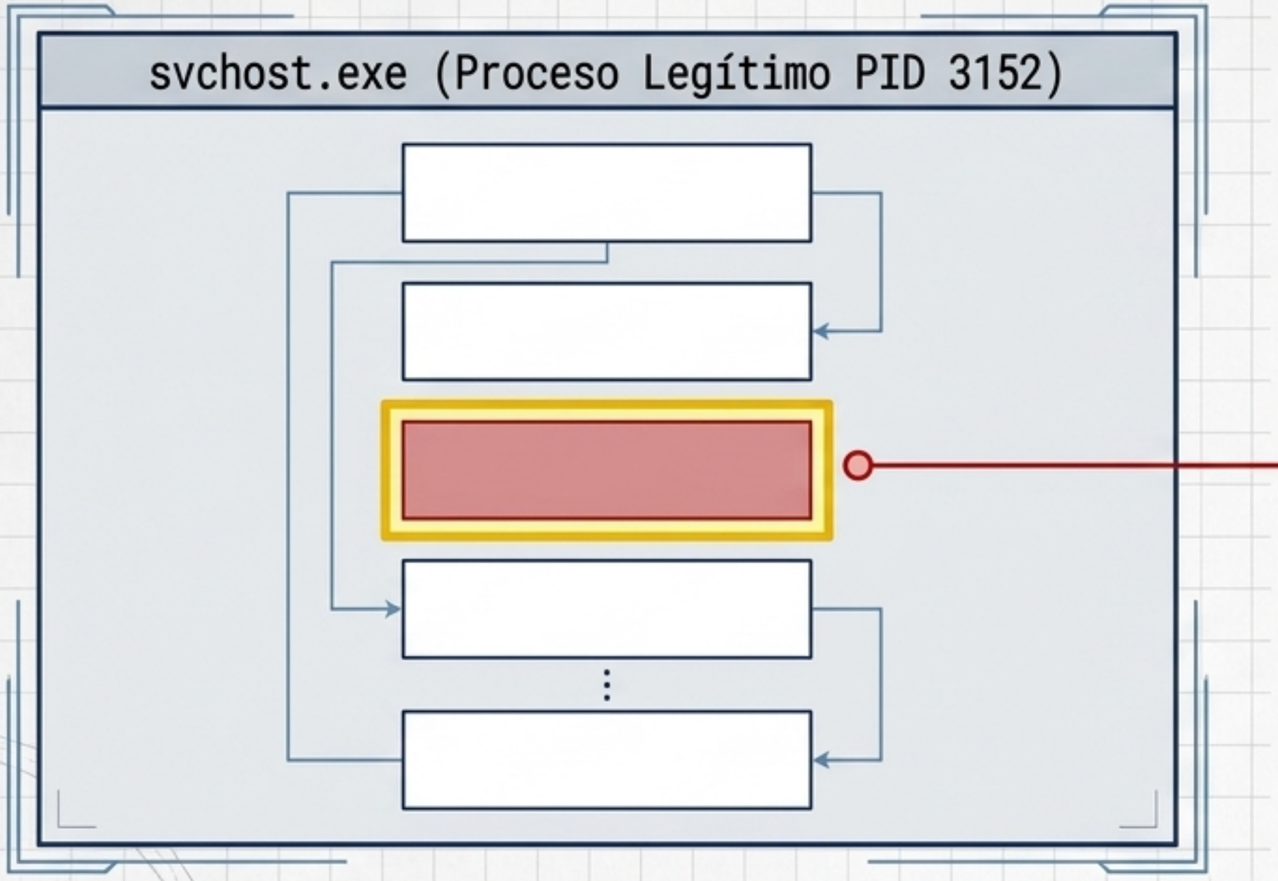
Ejecuta un barrido de fuerza bruta sobre los pools de memoria.
Descubre procesos en ejecución aunque hayan sido desenlazados.

Insight: La discrepancia entre `pslist` y `psscan` (verificable con `psxview`) es el principal indicador de una inyección maliciosa.

Gemini Notebook

Anatomía de la inyección en memoria (malfind)

El malware sofisticado inyecta su carga útil dentro de procesos legítimos del sistema para evadir antivirus.



Plugin: `malfind`

Bandera de permisos detectada:
`PAGE_EXECUTE_READWRITE`

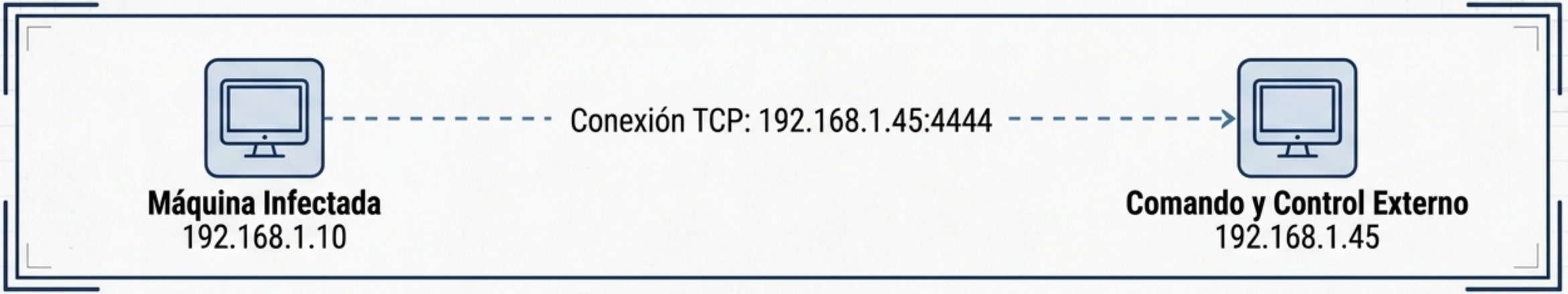
Los procesos normales de Windows rara vez utilizan esta combinación de lectura, escritura y ejecución simultánea, lo que delata instantáneamente el código inyectado.

Evidencia extraída: El volcado de esta región de memoria (VAD) permite recuperar el código del troyano para realizar ingeniería inversa.

Gemini Notebook

Rastreo de Mando y Control: Conexiones al descubierto

La memoria RAM captura los sockets de red TCP/UDP activos en el momento exacto de la adquisición.



Plugin: netscan

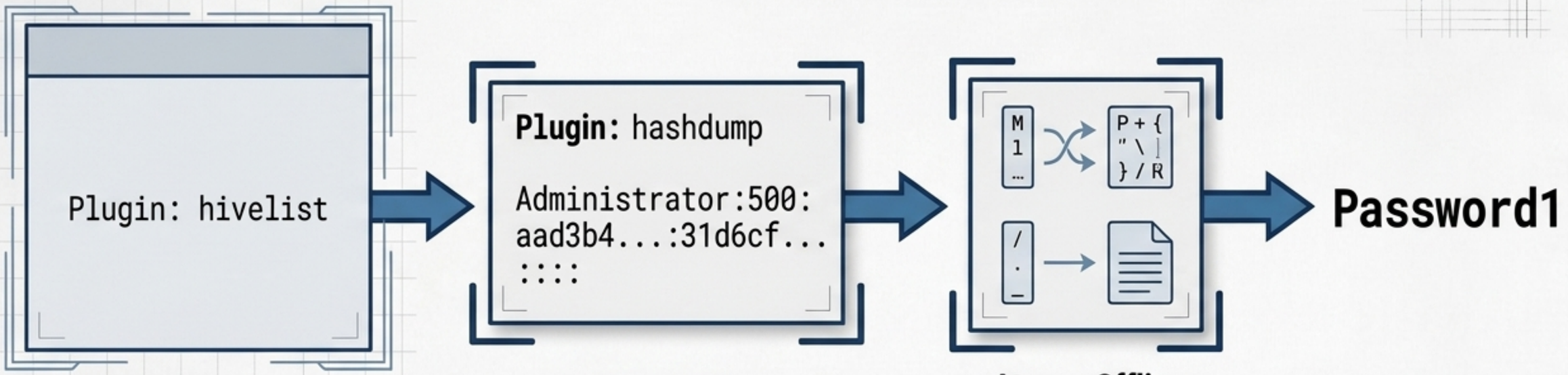
Offset(P)	Proto	Local Address	Foreign Address	State	PID
0x...	TCP	192.168.1.10	192.168.1.45:4444	ESTABLISHED	3152

Insight Forense: netscan vincula el proceso infectado (PID 3152) con una conexión saliente al puerto 4444, el puerto por defecto de las cargas útiles Meterpreter/Metasploit.

Gemini Notebook

Extrayendo las llaves del reino: Credenciales en memoria

La extracción de contraseñas de usuario directamente de la memoria permite saltar las protecciones del disco.



Colmenas del Registro
(SYSTEM y SAM)

Plugin: hashdump

Ataque Offline
(John the Ripper + rockyou.txt)

Los **hashes NTLM** recuperados se exportan y se rompen en el laboratorio utilizando herramientas de fuerza bruta o diccionarios para obtener las credenciales en texto claro.

Gemini Notebook

Rastros de navegación: Recuperación de actividad de usuario

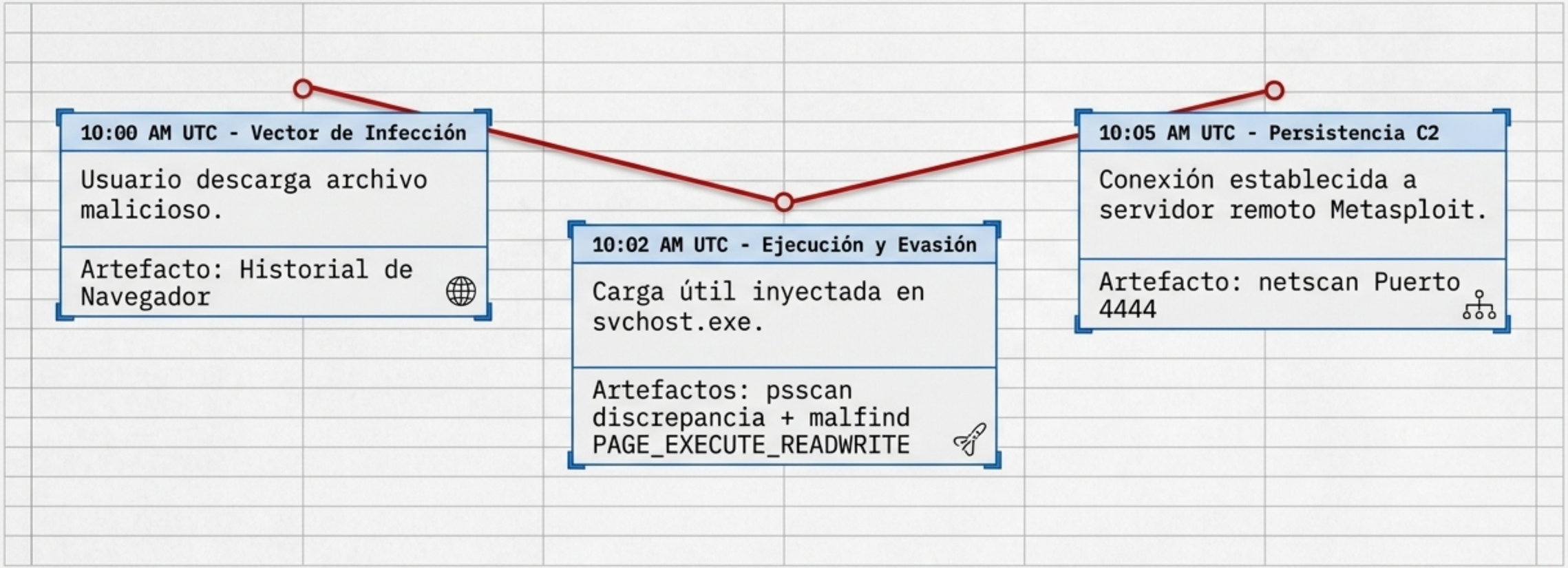
La memoria RAM es un repositorio inestimable para reconstruir la actividad humana inmediata, incluyendo navegación en modo incógnito.



Aplicación Táctica: Permite descubrir el vector inicial de infección, como el acceso a una web de phishing o la descarga de un archivo malicioso, horas antes de que se registren eventos persistentes.

Síntesis Forense: La Línea Temporal Reconstruida

El análisis termina al correlacionar cada artefacto en un informe técnico riguroso. El plugin timeliner automatiza la consolidación de estos eventos.



Gemini Notebook

“La memoria volátil guarda lo que el disco olvida.”

El Mandato del Analista

1. **Adquirir Primero:** La RAM es la evidencia más frágil; captúrela antes de cualquier otra interacción con el sistema.
2. **Asegurar Integridad:** Calcule el hash inmediatamente; la reproducibilidad convierte un análisis técnico en una prueba legal admisible.
3. **Cruzar Fuentes:** Nunca confíe en una sola métrica del sistema. Verifique siempre la realidad de la memoria cruda.

El GDT, el DTB y los pools de memoria hablarán por nosotros; solo hay que estar preparados para escucharlos.

Gemini Notebook